GUIA VISUAL 026

ROOT NO KALI, COM JUÍZO

Até 2019 o Kali abria o terminal como root. Desde a 2020.1, não — e isso muda o seu método.

026
GUIAS LINUX

O FLUXO DE MENOR PRIVILÉGIO

USUÁRIO KALI
UID 1000, no grupo `sudo`.
A conta root fica bloqueada (`!` no shadow): `su -` nem funciona.

→ **SEM PRIVILÉGIO — O DIA INTEIRO**
Navegar, ler PDF de relatório, editar, `git`, escrever scripts. Uma falha no navegador alcança só o que o `kali` alcança.

→ **ELEVAR UM COMANDO**
`sudo nmap -sS`, `sudo tcpdump`. Cada uso vira linha de log com `TTY`, `PWD` e `COMMAND`.

→ **ELEVAR A SESSÃO INTEIRA — EVITE**
`sudo -i` devolve os 3 defeitos do modelo antigo: erro fatal, tudo com poder máximo, nada auditável. Se precisar, use e feche **CEDO**.

CAPABILITY > SUDO
A ferramenta não quer root: quer `CAP_NET_RAW`. O `dumpcap` já vem com a capability e o grupo `wireshark` — captura **sem** sudo. Imite esse modelo.

NUNCA `curl | sudo bash`
Executa como root um código que você não leu, de uma origem que pode ter caído. Baixe → `less instala.sh` → só então `sudo bash`.

TRAVE E ISOLE
`sudo -k` ao se afastar (o cache de 15 min é root para quem sentar ali). Ferramenta duvidosa em contêiner; alvo e malware em **VM com snapshot**.

POR QUE A FERRAMENTA PEDE PRIVILÉGIO

FERRAMENTA	RECURSO QUE O KERNEL RESERVA
`nmap -sS`, `-sU`, `masscan`	*Raw socket* para forjar pacotes SYN/UDP (`CAP_NET_RAW`)
`tcpdump`, `wireshark`	Modo promíscuo e captura na interface
`airmon-ng`, `aircrack-ng`	Modo monitor no adaptador Wi-Fi
`ettercap`, `responder`, `arpspoof`	Injeção na camada de enlace (`CAP_NET_ADMIN`)
`losetup`, montar imagem	Manipular dispositivos de bloco

OS PRIMEIROS CINCO MINUTOS DE UMA VM KALI

kali@kali: ~

```
$ passwd                          # kali:kali e publico. Passo zero.
$ sudo apt update && sudo apt full-upgrade -y
$ sudo passwd -S root             # tem de dizer L (locked) — deixe assim
$ awk -F: '$3==0 {print $1}' /etc/passwd    # so pode sair "root"
$ find / -xdev -perm -4000 -type f 2>/dev/null | sort > ~/suid-baseline.txt
```

Antes de `dd`, `mkfs`, `wipefs` ou `cryptsetup luksFormat`: como root não há confirmação — um `of=` ou `/dev/sdX` trocado destrói o disco. Ensaie num arquivo-imagem: `truncate -s 1G /tmp/teste.img` → `sudo losetup -fP /tmp/teste.img` → pratique em `/dev/loopN` → `sudo losetup -d`. E confirme o alvo com `lsblk` **imediatamente antes** do comando.

RESUMO RÁPIDO

- ✓ Base sem privilégio; eleve **o comando**, nunca a sessão.
- ✓ Root bloqueado é o padrão do Kali — mantenha (`sudo passwd -l root`).
- ✓ Privilégio mínimo (*capability*, grupo) em vez de root inteiro.
- ✓ Destrutivo só depois de ensaio em `losetup` e conferência com `lsblk` .
- ✓ Baixe, **leia**, depois execute — nunca canalize script remoto para um shell privilegiado.

NO KALI

Capturar tráfego sem `sudo` : `sudo usermod -aG wireshark kali` + **novo login** (grupo suplementar entra no login). Cuidado: entrar no grupo `docker` é **equivalente a root** no hospedeiro — o contêiner isola a ferramenta, não quem fala com o daemon. No **WSL** o `sudo` pode vir `NOPASSWD` : cheque com `sudo -l` . E `sudo -l` numa conta de alvo **autorizado** é o 1º passo da escalada — sem escopo escrito, é crime (Lei 12.737/2012).